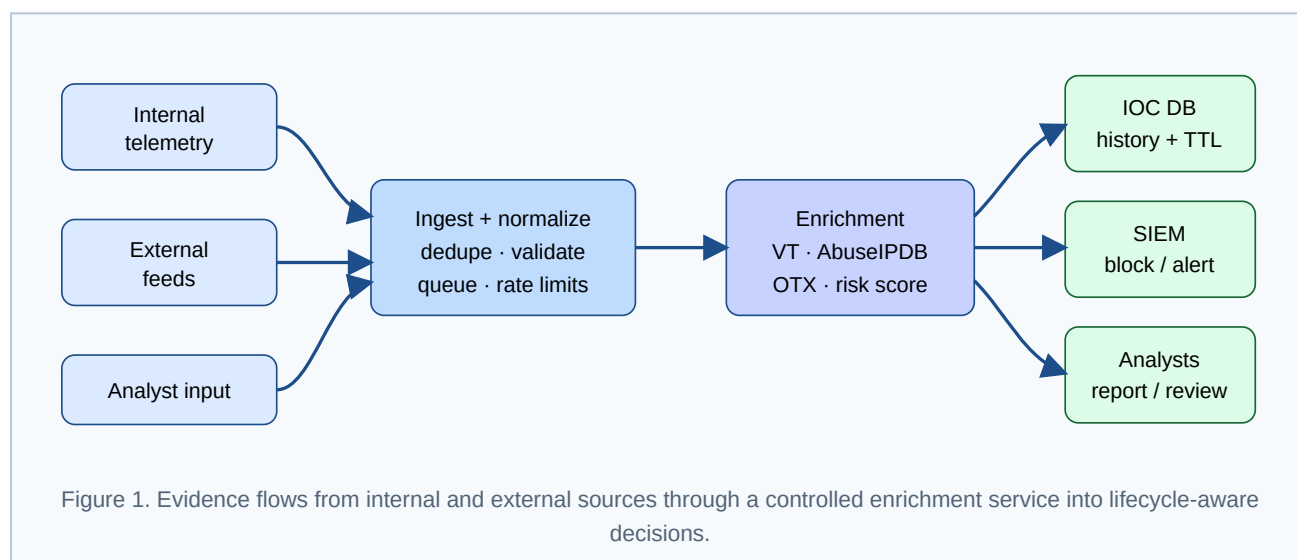


Task 1 — Threat Intelligence Platform Architecture

Enterprise SOC enrichment architecture

Purpose and design principles

The proposed threat intelligence (TI) platform gives a security operations centre (SOC) a repeatable path from an indicator of compromise (IOC) to a defensible decision. It separates collection, enrichment, storage, and action so that one unavailable provider cannot stop triage. Every result is retained with its source, observation time, confidence, and expiry. The design favours evidence over a single reputation verdict: analysts can see why an indicator was blocked, challenge a false positive, and reproduce the decision later.



Data sources and ingestion

Internal sources include endpoint detection and response (EDR), DNS and proxy logs, email security, firewall events, cloud audit logs, and analyst-submitted observables. They provide local context such as the affected asset, first seen time, and business owner. External sources include VirusTotal, AbuseIPDB, AlienVault OTX, vendor feeds, and the MISP community. MISP is used as the exchange and sharing model: its event, attribute, tagging, sighting, and distribution concepts map well to an IOC record while allowing sharing controls. The platform accepts IPs, domains, URLs, and file hashes, then canonicalizes case, whitespace, URL encoding, and indicator type before deduplication.

Enrichment engine and storage

A queue-backed enrichment worker fans out only to sources that support the indicator type. Each adapter has a timeout, schema validation, retry policy, and a circuit breaker. Results are normalized into a common evidence shape: provider, verdict, numeric score, tags, raw-reference identifier, observed_at,

and expires_at. A weighted risk score from 0 to 100 is computed from source confidence, malicious findings, abuse confidence, pulse counts, and source diversity. Missing data is not treated as clean; it is recorded as unavailable. Redis or an equivalent short-lived cache prevents repeated lookups, while PostgreSQL stores the durable IOC, evidence, sightings, analyst decisions, and audit history. Encryption is enabled in transit and at rest, and access is split between collectors, enrichment workers, analysts, and automation.

Workflow integration and controls

High-confidence, high-risk IOCs can create a SIEM correlation rule, EDR containment request, DNS or proxy blocklist entry, and analyst alert. Medium-risk items create a review queue instead of an automatic block. Analyst feedback is written back as a disposition with a reason and reviewer, and can be shared to MISP according to the event's distribution policy. A weekly report summarizes new IOCs, risk changes, expiring records, provider health, and false-positive reversals. Webhooks are signed and idempotent so a retried event cannot create duplicate actions.

Rate limits, expiration, and false-positive prevention

Provider quotas are enforced per credential with a token bucket and a queue rather than by uncontrolled retries. Responses such as HTTP 429 honour Retry-After; exponential backoff has jitter and a maximum delay. Cached evidence is returned during a provider outage when its freshness policy allows it, and the record is marked stale. Every IOC has a source-specific TTL. A scheduled expiration job removes expired evidence from active decisions, downgrades confidence, and requires re-enrichment before a block is renewed. Critical infrastructure, shared hosting, CDN ranges, and common services receive allowlist and asset-context checks before enforcement. Automatic blocking requires two independent sources or one source plus corroborating internal telemetry, a minimum score and confidence threshold, and no recent analyst suppression. Canary rollout, reversible actions, and sighting-based revalidation limit blast radius.

Governance and operations

Metrics cover queue age, cache hit rate, provider latency, error and quota rates, enrichment completeness, stale IOC count, block reversals, and analyst agreement. Health checks test credentials and a harmless known indicator without creating an enforcement action. Logs exclude API keys and sensitive raw payloads. The result is a platform that is useful during an incident but conservative enough for production: decisions are explainable, time-bounded, reversible, and traceable to evidence.

Ownership is explicit at each boundary. The SOC owns disposition and blocking policy, the platform team owns adapters and quotas, and threat researchers own source quality and tagging. A data-quality review compares provider disagreements, measures how often analysts overturn automated decisions, and retires feeds that create noise. Retention rules remove raw responses when their investigative value ends while preserving the normalized evidence and audit record required for incident review. This keeps the database useful without turning it into an uncontrolled archive.

Reference: MISP Project, *misp-project.org*, including the MISP data model and sharing concepts.